Remediation and Security-Hardening Checklist for example.com

1. Deprecate Unencrypted File Transfer Protocols

Observation: Port 21 (FTP) was detected as open on the target infrastructure. FTP transmits all data and authentication credentials in plaintext, making it highly susceptible to packet sniffing and Man-in-the-Middle (MitM) attacks.

Remediation: Disable the FTP service entirely. Replace it with secure, encrypted alternatives such as SFTP (SSH File Transfer Protocol) over port 22 or FTPS (FTP over SSL/TLS).

2. Enforce Strict Transport Layer Security (TLS)

Observation: Plaintext HTTP web traffic is currently permitted via ports 80 and 8080. While encrypted alternatives (443, 8443) are available, leaving plaintext ports active allows for potential downgrade attacks.

Remediation: Implement a global HTTP Strict Transport Security (HSTS) policy. Configure the Cloudflare edge proxy and the origin server to force permanent 301 redirects from ports 80 and 8080 to their encrypted HTTPS counterparts (443 and 8443).

3. Harden Email Transmission and Spoofing Defenses

Observation: Port 587 (Message Submission) is exposed to the internet. Passive recon confirmed a strict -all Sender Policy Framework (SPF) record is in place.

Remediation: Verify that the service on port 587 enforces STARTTLS encryption prior to accepting any authentication credentials. To complement the existing SPF record, implement DomainKeys Identified Mail (DKIM) and a Domain-based Message Authentication, Reporting, and Conformance (DMARC) record with a p=reject policy to comprehensively protect against domain spoofing.

4. Maintain and Monitor Domain Registrar Locks

Observation: The domain is currently safeguarded by clientDeleteProhibited, clientTransferProhibited, and clientUpdateProhibited EPP status codes.

Remediation: Maintain these administrative locks permanently to prevent unauthorized domain transfers or malicious DNS hijacking. Implement multi-factor authentication (MFA) on the registrar account controlling these statuses.

5. Restrict HTTP Methods

Observation: The web server headers explicitly allow GET and HEAD requests.

Remediation: This is a secure baseline. Ensure that administrative or destructive HTTP methods (such as PUT, DELETE, or TRACE) remain permanently disabled on the public-facing proxy to prevent unauthorized file uploads or Cross-Site Tracing (XST) attacks.